

漏洞报告 VULN-09：会话管理、登出与Cookie安全

漏洞类型：会话管理、登出与Cookie安全

测试小组：天亮了么

被测小组：天亮了么

测试时间：2026-08-28

测试环境：本机 localhost / 127.0.0.1:5001

测试账号：课程测试账号，未使用真实个人密码

1. 基本信息

本报告针对阶段二任务9，仅在授权的本机课程靶场中完成。

2. 漏洞位置

URL/接口： /login、/logout、/profile、/api/files; Flask Session

请求方法： GET/POST/DELETE（按接口实际方法）

关键参数： username、password、filename、file、csrf_token（按任务适用）

所属功能： 会话与Cookie

3. 正常请求

先使用正常账号和合法参数完成对应功能，再仅修改一个测试参数。请求记录和页面证据见附件目录。

正常请求示例：在本机浏览器访问对应页面，提交课程测试账号或合法文件；不包含真实密码、Cookie 或 Token。

4. 漏洞复现步骤

1. 启动本机网盘并登录课程测试账号。
2. 按任务说明构造单一无害测试参数。
3. 发送请求并记录状态码、页面、文件或会话变化。
4. 使用修复后的同一参数再次验证。

5. 攻击效果或异常现象

登录前后 Session 值发生变化；Cookie 具备 HttpOnly、SameSite=Lax；退出后访问核心 API 返回 401。

6. 漏洞原因分析

会话生命周期和 Cookie 属性需要显式安全配置。

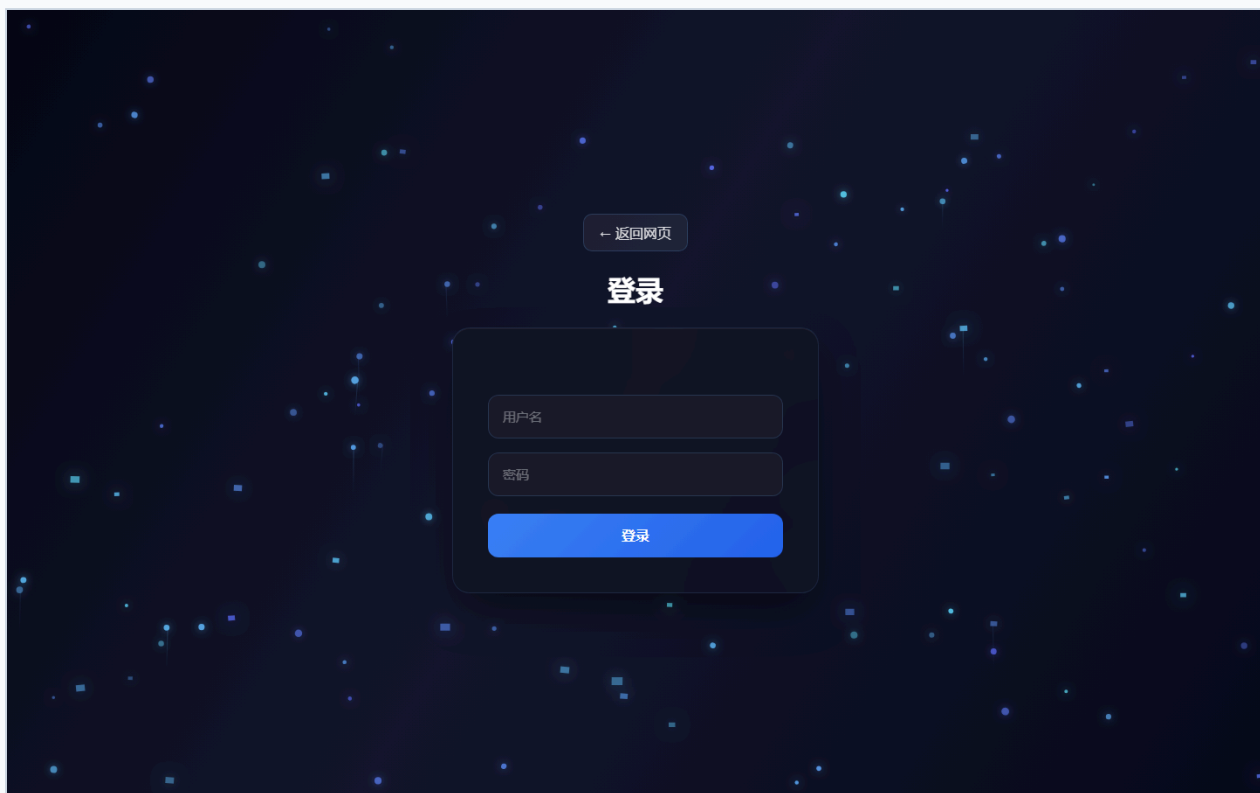
7. 影响范围

影响范围限于本机课程靶场及测试账号；不得外推为公网系统影响。具体后果取决于接口是否需要登录及资源归属。

8. 修复建议

启用 HttpOnly、SameSite=Lax 和可选 Secure；登录成功前清理旧 Session；退出 session.clear()；核心接口统一认证。

9. 附件清单



云 个人网盘

首页文件相册传输分享

搜索文件、图片、视频

退出登录

纯

上传文件



野兽先辈

下北泽电子科技大学 学生

你的个人云盘首页

集中管理课程资料、图片、视频和个人文件。这里保留了原 profile 页面里的头像与视频内容，并改造成网盘首页布局。

24

年龄

1919114514

学号

VibeCoding

兴趣标签

开始上传

文件列表

全部文件

图片

视频

文档

收藏

回收站

空间使用

42.6 GB

已使用 42%，剩余空间充足

图片文件

排序筛选



最近文件

列表

名称	类型	修改时间	大小
 课程资料	文件夹	今天 16:40	--
 数据库作业说明.docx	文档	昨天 21:18	1.8 MB
 首页设计参考.png	图片	5 月 16 日	3.4 MB
 项目演示视频.mp4	视频	5 月 15 日	128 MB

pyknb 的文件

上传新文件

返回个人主页

退出登录

文件名	操作
44286_2023_2_Fig5_HTML.webp	下载 删除
fake.png	下载 删除
scriptalert1_script.png	下载 删除

[← 返回网页](#)

登录

用户名

密码

登录

任务 09 修复代码证据

gets.py:195-215

```
195         if user and user[1].startswith(("pbkdf2:", "scrypt:"))
196             else bool(user) and user[1] == password
197     )
198     if not valid:
199         record_login_failure(username)
200         response = {"error": "用户名或密码错误"}
201         return (jsonify(response), 401) if as_api else ("用户名或密码错误", 401)
202     clear_login_failures(username)
203     session.clear()
204     csrf_token()
205     session["username"] = username
206     if user and not user[1].startswith(("pbkdf2:", "scrypt:")):
207         conn = get_db_connection()
208         try:
209             with conn.cursor() as cursor:
210                 cursor.execute("UPDATE users SET password=%s WHERE username=%s", (generate_password_hash(password), username))
211             conn.commit()
212         finally:
213             conn.close()
214     security_logger.info("login_success username=%s ip=%s", username, client_ip())
215     if as_api:
```

gets.py:238-258

```
238
239 @app.post("/api/logout")
240 @csrf_protected
241 def api_logout():
242     session.clear()
243     return jsonify({"success": True})
244
245
246 @app.get("/profile")
247 def profile():
248     if "username" not in session:
249         return redirect("/login")
250     return render_template("profile.html")
251
252
253 @app.get("/logout")
254 def logout():
255     session.clear()
256     security_logger.info("logout ip=%s", client_ip())
257     return redirect("/")
258
```